MODULE 4 · LECTURE 23

CS 6530 Applied Cryptography

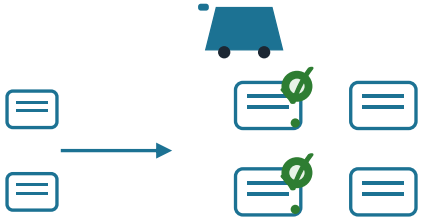
Key and Certificate Management Protocols

Module 4 – Key Management, Certificates and PKI

PKI AT SCALE

Certificate Management at Scale – Life cycle including provisioning and retirement

E-COMMERCE

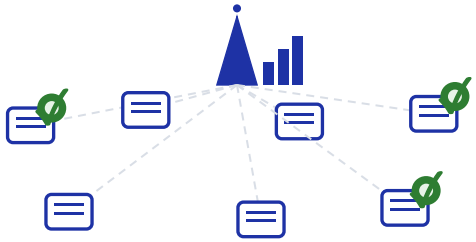


Festival / peak demand → infrastructure scales rapidly

Service identities and credentials must be provisioned and retired as infrastructure scale.

Can every certificate be deployed and renewed manually?

TELECOM NETWORK

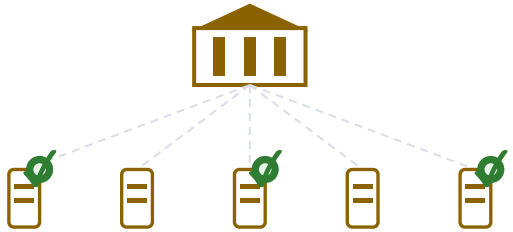


Large numbers of distributed network elements

Identities need enrollment, renewal, replacement.

How are credentials updated across the network?

BANKING



Large distributed machine population

Machine identities need secure lifecycle management.

How are credentials updated across thousands of machines?

CREATE / ENROLL → ISSUE → DEPLOY / USE → RENEW / RE-KEY → REVOKE / EXPIRE → RETIRE / DESTROY KEYS

At scale, certificate lifecycle management must be automated.

How? → CMPv2 • BRSKI • EST • ACME

INSIGHT

Automation is essential once identities and certificates span large, changing infrastructures.

? THINK LIKE AN ENGINEER

What could go wrong if certificate renewal depended on people remembering expiry dates?

At scale, certificate management is an automation problem—not just an issuance problem.

CMP — Who Talks to Whom?

CMPv2 for Automated Certificate Management

CMPv2 enables authenticated and protected certificate lifecycle operations between end entities and the PKI, directly or via a Registration Authority.

Widely Used in Telecom

CMPv2 is widely deployed and profiled in telecom networks (e.g., 3GPP TS 33.310) for automated certificate lifecycle management of network elements.

Network / End Entities (EEs)

Many managed nodes (e.g., thousands)

- Base Station (gNodeB/eNodeB)
- Core Network Function (e.g., AMF)
- Router / Gateway
- Network Server
- IoT / Industrial Device
- Many more network elements

Option 1: Direct to CA

CMPv2

(protected management messages)

Option 2: Via Registration Authority (RA)

CMPv2 — **Registration Authority (RA)** (optional) — CMPv2

- Identity verification
- Policy checks
- Enrollment forwarding

PKI / Certification Authority

Certificate Authority (CA)

- Issues certificates
- Processes CMPv2 requests
- Manages certificate lifecycle
- Maintains CA database

Supports Scalable Operations

Designed for automated certificate management across large populations of devices and network elements.

Protected Exchanges

CMPv2 messages are authenticated and integrity-protected (e.g., using signatures or MACs).

Flexible Deployment

End entities may communicate with the CA directly or via one or more intermediate PKI management entities such as an RA.

CMPv2 enables automated, protected certificate management between end entities and the PKI.

CMPv2 — Management Operations and Protected Messages

CMPv2 Management Operations

CMPv2 defines messages for the full certificate lifecycle.

Function	CMP Message(s)
Initial Registration	ir → ip
Certificate Request	cr → cp
Key / Certificate Update	kur → kup
Revocation	rr → rp
General Management	genm → genp

Supporting Exchanges

Certificate Confirmation	certConf → pkiConf
Delayed Processing	pollReq ↔ pollRep

Inside a CMPv2 PKIMessage

CMPv2 messages are authenticated and integrity-protected.

PKIMessage

PKIHeader *Who? To whom? Which transaction?*	• sender / recipient • transactionID • nonces • protectionAlg Identifies the management operation.
PKIBody *What management operation?* ir • ip • cr • cp • kur • kup • rr • …	
protection (optional) *Cryptographic message protection*	• signature or MAC • ensures integrity and authenticity
extraCerts (optional) *Supporting certificates*	• May include additional certificates (e.g., RA cert, chain, etc.)

Key Points

1. Standardized protocol for certificate lifecycle management.
2. Supports direct EE–CA or EE–RA–CA deployments.
3. Authenticated and protected exchanges (signature or MAC).
4. Widely used in telecom and managed network environments.
5. Supports automation at scale (e.g., thousands of devices).

Security Aspects

Message Protection
Ensures authenticity and integrity of CMP messages (signature or MAC).

Proof of Possession (POP)
Verifies that the requester holds the private key corresponding to the requested public key.

Authorization and Policy
RA/CA enforce identity, policy and certificate profiles.

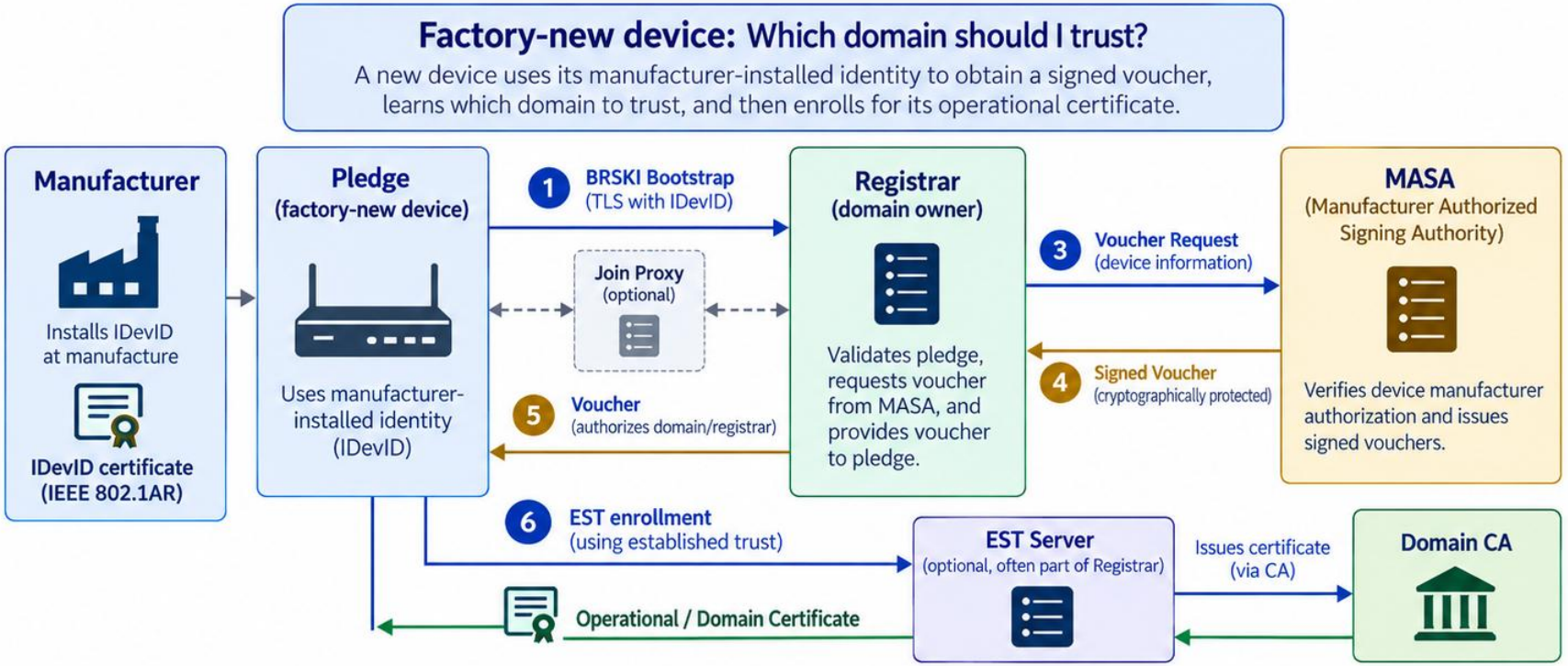
Used over secure transport
e.g., HTTPS (TLS).

Relevant Standards

RFC 4210	Certificate Management Protocol (CMP) (2005)
RFC 9480	CMP Updates (2019)
RFC 9810	CMPv2 (2025) – current specification
RFC 9483	CMPv3 (2023) – further updates
Related	Often used with EST (RFC 7030) and in telecom/managed PKI environments.

CMPv2 provides a flexible and secure framework for automated certificate management.

BRSKI — From Factory Identity to Domain Trust



Key Actors

- **Pledge** — Prospective, unconfigured device with manufacturer-installed identity (IDevID).
- **Registrar** — Represents the local domain owner. Acts as bootstrap authority (often performs RA functions).
- **MASA** — Manufacturer Authorized Signing Authority. Validates device manufacturer authorization and issues signed vouchers.
- **Voucher** — Cryptographically signed artifact that authorizes the pledge to securely join the indicated registrar/domain.

Flow Summary

1. Pledge initiates BRSKI using its IDevID in a TLS connection to the registrar (directly or via an optional Join Proxy).
2. Registrar validates the pledge and sends a voucher request to the MASA.
3. MASA returns a signed voucher to the registrar.
4. Registrar provides the voucher to the pledge.
5. Pledge validates the voucher and learns which domain/registrar to trust.
6. Pledge uses the established trust to enroll for its operational certificate using EST (RFC 7030).

Relevant Standards

RFC 8995	BRSKI: Bootstrapping Remote Secure Key Infrastructures (2021)
RFC 8366	Voucher Artifact for BRSKI (2018)
RFC 7030	EST: Enrollment over Secure Transport (2013)
IEEE 802.1AR	Secure Device Identity (IDevID) (2010)

BRSKI is defined as extensions to EST. The voucher format is specified in RFC 8366. Devices typically have an IDevID as defined in IEEE 802.1AR.

BRSKI bootstraps trust: the pledge securely learns which domain/registrar to trust before normal certificate enrollment.

ENROLLMENT OVER SECURE TRANSPORT (EST)

EST — Enroll and Renew Certificates Securely

Enroll and renew certificates over a secure channel

EST uses HTTPS/TLS to enable clients to obtain, renew and manage certificates in a simple and interoperable way.

EST Client (Device / Application)



Has a trusted network connection to the EST server



Generates key pair and creates CSR (PKCS #10)

1. **Get CA Certificates**
   GET /.well-known/est/cacerts
   ← CA certificate(s)
2. **Enroll for Certificate**
   POST /simpleenroll
   → CSR (PKCS #10) + proof of possession (e.g., CSR signature)
   ← Issued certificate
3. **Renew / Re-key**
   POST /simplereenroll
   → CSR (for renewal) + proof of possession
   ← Renewed certificate

EST Server



- Terminates HTTPS/TLS
- Authenticates client (e.g., TLS client cert, HTTP auth, or other)
- Processes EST requests
- Validates CSR and proof of possession
- Interacts with CA
- Returns certificates

CA protocol (e.g., CMP)

Certificate Authority (CA)



- Validates request and policy
- Issues certificates
- May be co-located with EST server or external

Key EST Operations (HTTP Endpoints)

GET /.well-known/est/cacerts
- Obtain CA certificate(s)
- Used to bootstrap trust

POST /simpleenroll
- Enroll for a certificate
- Carries a PKCS #10 CSR
- CSR signature provides proof of possession (for a signing key)

POST /simplereenroll
- Renew or re-key an existing certificate
- Carries a PKCS #10 CSR

How It Works (Simplified Flow)

1. Client retrieves the CA certificate(s) from the EST server (/.well-known/est/cacerts).
2. Client sends a certificate signing request (CSR) to / **simpleenroll** over HTTPS. The CSR is signed with the client's private key, providing proof of possession.
3. Server validates the request, interacts with the CA, and returns the issued certificate.
4. For renewal or key update, the client sends a new CSR to / **simplereenroll** and receives a renewed certificate.

All EST exchanges are protected by HTTPS/TLS (mutual authentication is commonly used).

Key Points

- Uses HTTPS/TLS for secure transport.
- Simple and lightweight REST/HTTP interface.
- CSR signature provides proof of possession (for a signing key).
- Supports enrollment, re-enrollment and key update.
- Widely implemented and used in enterprise, network and device environments.

Relevant Standard

RFC 7030 — EST: Enrollment over Secure Transport (2013)

Defines the EST protocol, HTTP endpoints, message formats and security considerations.

Typical Deployment Scenarios

- Network devices (routers, switches, base stations)
- Enterprise systems and servers
- Managed endpoints (laptops, IoT devices)
- Often used after initial trust is established (e.g., via BRSKI, pre-provisioning, or existing PKI).

EST provides a straightforward and secure way to enroll and re-enroll for certificates using HTTPS/TLS.

ACME — Automated Certificate Management for Internet Services

Automatically obtain and renew certificates for Internet services

ACME enables a client to prove control of a domain identifier and automatically obtain, renew and manage certificates from a CA.

ACME Client
(Web server / Application)

- Runs an ACME client (e.g., certbot)
- Manages account, orders and challenges
- Responds to validation challenges
- Generates CSR and installs certificate

1. **Create / Use Account** — Register a new account or use existing account
   → Account created / confirmed
2. **Create Order** — Request certificate for domain name (e.g., example.com)
   → Order details (authorizations)
3. **Complete Challenge(s)** — Prove control of the domain identifier
   → Authorization successful
4. **Finalize (Submit CSR)** — Send CSR after successful authorization
   → Certificate issued

ACME Server / CA

- Manages accounts
- Creates and tracks orders
- Issues and validates challenges
- Verifies control of identifiers (e.g., domain names)
- Issues certificates
- Supports renewal and revocation

DNS queries (for DNS-01)

Domain Name System (DNS)

- Holds DNS records for the domain
- Used for DNS-01 challenge

HTTP/HTTPS (for HTTP-01)

Web Server (Domain)

- Hosts content for the domain
- Used for HTTP-01 challenge (temporary token file)

ACME Flow in Steps

1. **Create / Use Account** — Register a new ACME account (or use an existing one).
2. **Create Order** — Request a certificate for the domain name.
3. **Complete Challenge(s)** — Prove control of the domain identifier (e.g., HTTP-01, DNS-01, TLS-ALPN-01).
4. **Finalize (Submit CSR)** — After successful authorization, submit a CSR.
5. **Certificate Issued** — Receive and install the certificate. Client can renew automatically before expiry.

Challenge Types (examples)

HTTP-01
- Place a token file at http://<domain>/.well-known/acme-challenge/<token>
- CA fetches the file over HTTP.

DNS-01
- Create a TXT record _acme-challenge.<domain>
- CA verifies the DNS record.

TLS-ALPN-01
- Respond to a TLS connection using ALPN "acme-tls/1"
- Present a special validation certificate.

Key Points

- Automates certificate issuance and renewal.
- Proves control of the domain identifier (not device identity).
- Widely used for Internet-facing services (e.g., web servers).
- Supports short-lived certificates and automated renewal.
- Uses simple, interoperable HTTP-based protocol (JSON over HTTPS).
- Many clients and CAs support ACME (e.g., certbot, Let's Encrypt, commercial CAs).

Relevant Standard

RFC 8555
ACME: Automated Certificate Management Environment (2019)

Typical Deployment Scenarios

- Public web servers (e.g., www.example.com)
- Cloud services and infrastructure
- Load balancers and reverse proxies
- Containerized and cloud-native deployments (e.g., Kubernetes, microservices)
- Automated DevOps / CI-CD environments

ACME enables automated, scalable and secure certificate management for Internet services.

Which Protocol for Which Deployment?

CMPv2

Automated certificate management for managed environments.



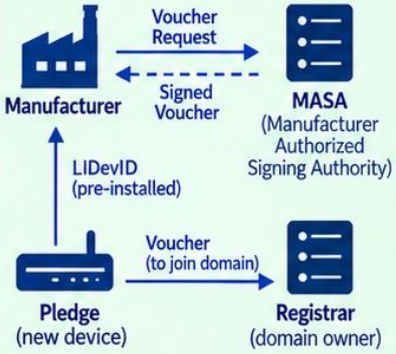
- Rich certificate lifecycle management (enroll, update, revoke, key recovery, etc.).
- Supports direct EE–CA or EE–RA–CA deployments.
- Authenticated and protected messages (signatures or MAC).
- Widely used in telecom and managed network environments.

Key Standards

RFC 4210	CMP (2005)
RFC 9480	CMP Updates (2019)
RFC 9810	CMPv2 (2025)

BRSKI

Secure bootstrap of a new device to discover the domain to trust.



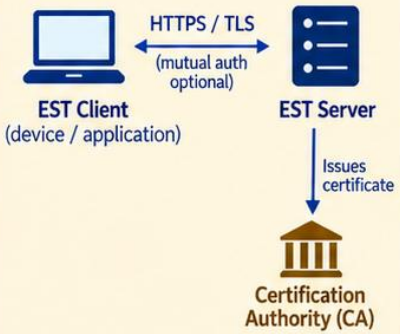
- Uses manufacturer-installed IDevID for initial trust.
- Obtains a signed voucher from MASA via a registrar.
- Learns which domain/registrar to trust.
- Typically followed by EST enrollment for the operational certificate.

Key Standards

RFC 8995	BRSKI (2021)
RFC 8366	Voucher Format (2018)
IEEE 802.1AR	IDevID (2010)

EST

Certificate enrollment and re-enrollment over a secure channel.



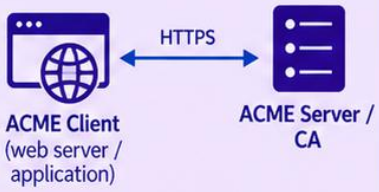
- Uses HTTPS/TLS for secure transport.
- Simple enrollment with PKCS #10 CSR.
- CSR signature provides proof of possession (for a signing key).
- Supports enrollment, re-enrollment and certificate retrieval.
- Widely used in enterprise and device environments.

Key Standard

RFC 7030	EST (2013)

ACME

Automated certificate management for Internet-facing services.



- Proves control of a domain identifier using challenges (e.g., HTTP-01, DNS-01, TLS-ALPN-01).
- Automates certificate issuance and renewal.
- Uses a simple, interoperable HTTP-based protocol (JSON).
- Widely used for Internet services (e.g., web servers, cloud services).

Key Standard

RFC 8555	ACME (2019)

Different problems → Different protocols → Complementary roles

Managed / operator environments — Devices and enterprise systems — Internet-facing services

STANDARDS & FURTHER READING

References

1 — CMP

RFC 9810
Internet X.509 Public Key Infrastructure — Certificate Management Protocol (CMP)

RFC 9811
HTTP Transfer for the Certificate Management Protocol (CMP)

3GPP TS 33.310
Network Domain Security (NDS); Authentication Framework

2 — ACME

RFC 8555
Automatic Certificate Management Environment (ACME)

3 — BRSKI

RFC 8995
Bootstrapping Remote Secure Key Infrastructure (BRSKI)

RFC 8366
A Voucher Artifact for Bootstrapping Protocols

IEEE 802.1AR
Secure Device Identity

4 — EST

RFC 7030
Enrollment over Secure Transport